RBC CAPITAL MARKETS · DIGITAL ASSET TECHNOLOGY · INCIDENT UPDATE

Binance hack: pre-signed transactions and the DevOps path

What happened on 29 October 2026, how pre-signed EIP-7702 authorizations turned a hot wallet into an attacker's sweeper, and the DevOps and signing controls an institutional custody and settlement stack should test now.

JP Creedon · Head of Digital Asset Technology, RBC Capital Markets · October 30, 2026 · Public sources only; Binance post-mortem not yet published

Bottom line: nobody appears to have stolen a private key. Binance says a compromised DevOps engineer's laptop led to a service container that submitted withdrawal requests, and the hot-wallet signing pipeline signed them[1,4]. On Ethereum the attacker had that pipeline sign **50 EIP-7702 authorizations in advance**, one per upcoming nonce, so one would still be valid when broadcast; it delegated Binance's hot wallet to a sweeper contract[2,3]. The lesson for us is not about custody keys. It is about **what a signer will agree to sign, who can ask it, and how fast we notice**.

~$6.3B
estimated impact (Binance); TRM traces $6.36B, Chainalysis ~$6.4B

10 chains
drained, most in ~20 min from 20:05 UTC (4:05 PM ET)

50
pre-signed EIP-7702 authorizations in one carrier transaction

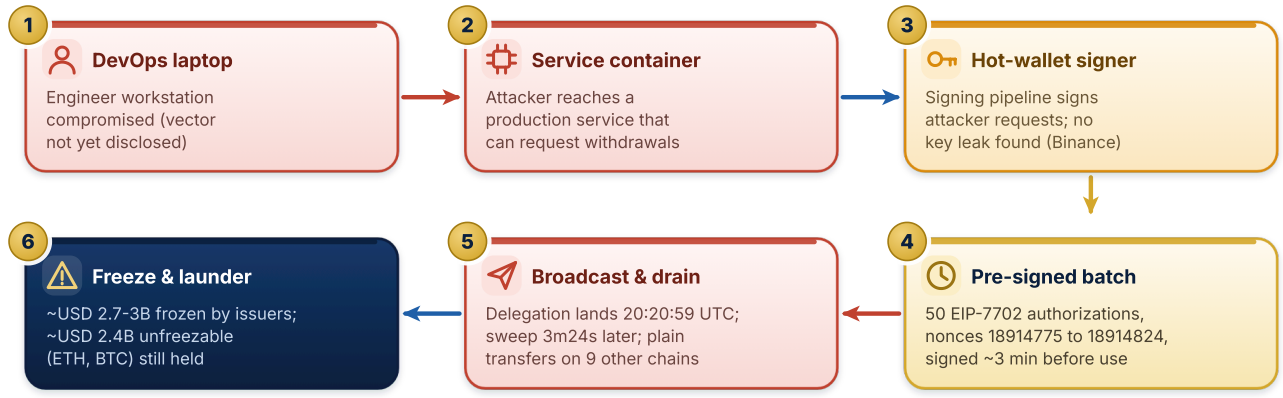
~$2.7-3B
frozen on-chain (TRM ~$2.7B; Binance ~$3B); ~$2.4B out of reach

Status key: CONFIRMED stated by Binance or visible on-chain · ANALYST FINDING from blockchain-analytics firms or researchers · UNCONFIRMED reported or claimed but not verified · OUR ANALYSIS our inference. Times in ET (UTC-4) unless marked UTC.

Topic	What we know	Status	What it means for us
When / where	29 Oct 2026, from ~4:05 PM ET (20:05 UTC). Binance.com hot wallets; Binance.US says it was not affected[2,6]	CONFIRMED	Hot-wallet tier, not cold storage, was the blast radius
How much	~$6.3B (Binance); $6.36B at time-of-theft prices across 10 chains (TRM)[1,2]	CONFIRMED ANALYST FINDING	Largest crypto theft on record, ~4x Bybit (Feb 2025)
Entry point	Compromised DevOps laptop → service container → unauthorized withdrawal transactions. Binance: "not a single one-click action"; "additional points of breach" found, not yet described[1,4,6]	CONFIRMED UNCONFIRMED	Engineering access to production request paths is a custody risk, not only an IT risk
Keys	"No evidence of any wallet private key leak." Analysts read it as signer misuse, not key theft[1,7]	CONFIRMED ANALYST FINDING	MPC/HSM alone does not help if the signer accepts the attacker's requests
Pre-signed role	50 authorizations, consecutive nonces, signed ~3 min before broadcast; one matched; sweeper drained 167,464 ETH + 63 tokens; delegation persisted ~3h50m with repeat sweeps[2,3]	ANALYST FINDING	Signers must parse every payload type; delegation must be monitored and revocable in minutes
Other chains	XRP, BTC, Tron, Solana, Arbitrum, Optimism, Base, Avalanche, Polygon drained by ordinary signed transfers[2,3]	ANALYST FINDING	One compromised path signed for every chain; segregate signers
Attribution	TraderTraitor / Lazarus (North Korea), "high confidence" (TRM, Chainalysis). Not confirmed by Binance or law enforcement[2,4,5]	ANALYST FINDING UNCONFIRMED	Same actor as Bybit; expect social engineering of engineers
Binance response	Withdrawals suspended; affected address authorization revoked; losses covered by SAFU and company funds; >$6.3B reserved; post-mortem and Proof of Reserves to follow[1,6]	CONFIRMED	Watch for the root cause; re-check our controls when it lands
Mitigations	Our analysis: controls at each hop could have stopped or capped this. Strongest: a signer that parses intent itself and refuses multi-nonce or no-amount/no-destination permission messages; independent co-signing; caps and low hot balances; a minutes-level kill switch	OUR ANALYSIS	See section 04: each attack step mapped to PREVENT / DETECT / LIMIT
Status now	Withdrawals target resumption "in 45 hours" (Binance on X, 30 Oct); deposits open; recovery under way[6,10]	CONFIRMED	Counterparty exposure: no solvency concern flagged by Fundstrat[5]

WHAT HAPPENED

01 Attack path and timeline



Attack path as reported. Steps 1-2 are Binance's initial finding; steps 3-6 are reconstructed by TRM, 808bits and Blockaid from on-chain data. How the container could reach the signer is not yet public.[1,2,3,7]

ET (Oct 29)	UTC	Event
Oct 28 AM	—	Operator wallet funded by three small Tornado Cash withdrawals; staging begins ≥36 h ahead[2]
Oct 28, 10:28 PM	**Oct 29 02:28**	Carrier wallet deploys a sweeper and rehearses EIP-7702 delegation on throwaway wallets; revised sweeper and second rehearsal at 15:59 UTC (11:59 AM ET)[3]
4:05 PM	**20:05**	First theft: five Binance XRP Ledger wallets send 233.46M XRP[2,3]
4:10 PM	**20:10**	Solana (~970k SOL) and Optimism follow[2]
4:17:47 PM	**20:17:47**	Nonce 18914775 becomes live on Binance 14: the earliest of the 50 authorizations, so the batch was signed after this point[3]
4:20 PM	**20:20**	Binance BTC hot wallet sends 18,270 BTC (peel chain begins); Tron hot wallet sends 612.7M USDT within 2 min[2]
4:20:59 PM	**20:20:59**	Carrier tx with 50 authorizations lands (block 26300753); entry 16 (nonce 18914809) takes effect[3]
4:24:23 PM	**20:24:23**	Sweeper drains Binance 14: 167,464 ETH + 63 tokens incl. 1.615B USDT[2,3]
5:01-5:04 PM	**21:01-21:04**	Tether freezes 971.1M USDT; Circle freezes 823M USDC[2]
4:41-7:56 PM	**20:41-23:56**	Repeat sweeps as new deposits reach the still-delegated wallet; second wave on Avalanche, Polygon at 23:05 UTC[2]
8:10:35 PM	**00:10:35 (30th)**	Binance revokes the delegation (authorization to zero address)[3]
10:25 PM	**02:25 (30th)**	Binance: compromised DevOps laptop; no key leak; ~$6.3B; ~$3B frozen[1,6]

TRM figures as of 30 Oct 00:30 UTC (8:30 PM ET, 29 Oct). Totals differ between sources because of pricing time and freeze updates; we quote each with its source.

CORE ANGLE

02 Pre-signed transactions: the purpose and the trap

What a pre-signed transaction is

A transaction or authorization signed now and broadcast later. Once signed, anyone who holds the blob can submit it; the chain only checks that the signature and nonce are valid. It is a bearer instrument for as long as its nonce, expiry or chain state allows.

Why custodians use them

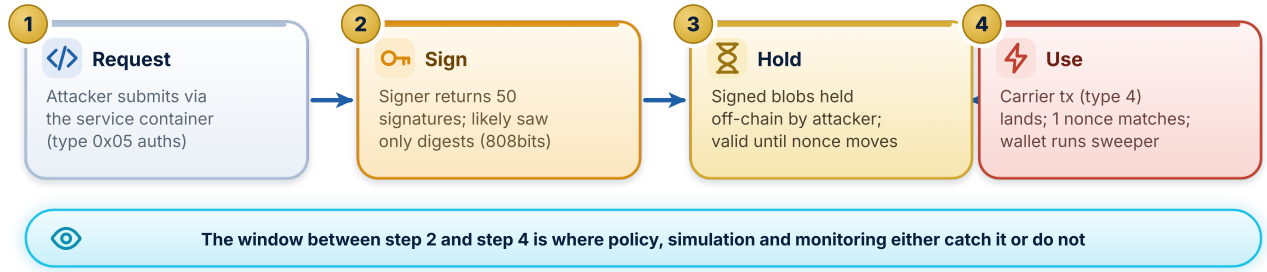
- **Recovery and break-glass:** pre-signed sweeps to cold storage if a signer is lost.
- **Sweeps and rebalancing:** deposit-address consolidation, hot/warm top-ups.
- **Time-locks:** vault exits or escrow that should execute later.
- **Operational efficiency:** batch signing in a ceremony, broadcast by automation; gas sponsorship.

What the signer actually signed here

An EIP-7702 authorization is not a transaction. It is a signature over 29 bytes: a type marker, chain id, a delegate address, and a nonce[3]:

```
05                  EIP-7702 magic byte
db                  list, 27 bytes
  01                chain id 1 (Ethereum)
  94 63e842b0…6fae  delegate: sweeper contract
  84 01209df9       nonce 18914809
```

No destination, no amount, no data field. A policy engine that checks those fields has nothing to check; a signer handed only a 32-byte hash cannot tell it from a normal withdrawal[3]. Once accepted, the wallet runs the sweeper's code until a new authorization replaces it.



Pre-signed lifecycle in this incident. Signatures were requested as a batch, held briefly, then carried on-chain by an attacker-funded wallet. 34 of the 50 were already stale, one was used, 15 were spare.[3]

IMPORTANT NUANCE

These were **not** a stash of Binance's own recovery transactions that leaked. As reported, the attacker obtained fresh signatures from the live pipeline minutes before use and pre-signed a nonce window because a busy hot wallet (33 transactions in the prior 3 minutes) moves its nonce every few seconds[3]. TRM notes "signatures obtained in advance then executed in one burst" as a recurring TraderTraitor pattern (Bybit, KelpDAO)[2]. ANALYST FINDING

ATTACK SURFACE

Where pre-signed and blind-signing risk lives

Opaque payloads — SIGNER

Signing raw digests or typed objects the policy engine does not parse (here 0x05 authorizations). Policy sees nothing, approves by default.

Nonce windows and replay — CHAIN

A batch over consecutive nonces guarantees one hits. Pre-signed blobs stay valid until the nonce passes; chain id or nonce reuse can enable replay.

Storage of signed blobs — OPS

Recovery and sweep transactions held in tickets, buckets or repos are bearer instruments. Who can read them can broadcast them.

Signing-UI integrity — FRONT-END

Bybit 2025: the signers' Safe{Wallet} UI was altered so approvers saw a transfer while signing a contract change[11]. What you see must be rebuilt independently.

Simulation gaps — PRE-TRADE

Simulating the transfer is not enough: simulate the state after (code at the address, owner changes, approvals) and the next calls it enables.

Persistent effects — POST-TRADE

A 7702 delegation stays until replaced; Binance 14 kept running the attacker's code ~3h50m and was re-swept six times[2,3]. Detection and revocation speed matter as much as prevention.

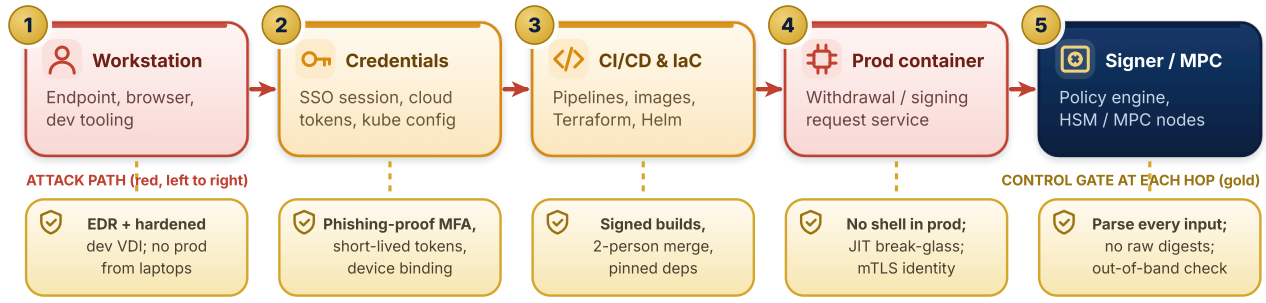
Bybit (Feb 2025) vs Binance (Oct 2026)

	Bybit, Feb 2025	Binance, Oct 2026
Loss	~$1.5B (≈400,000 ETH)[11]	**~$6.3B across 10 chains[1,2]**
Initial access	Safe{Wallet} developer's macOS workstation, social engineering; AWS session tokens reused[11]	**Binance DevOps engineer's laptop; vector not disclosed[1]**
What was tampered	Third-party signing front-end (JavaScript on AWS S3) [11]	**Internal service container that submits withdrawals[1]**
Wallet tier	Cold multisig (Safe)	**Hot wallets, many chains**
Payload trick	Transfer displayed; delegatecall that swapped the wallet's implementation actually signed[11]	**EIP-7702 authorization with no amount or destination; plain transfers elsewhere[2,3]**
Key stolen?	No: humans signed a manipulated transaction	**No evidence (Binance): pipeline signed attacker requests**
Shared lesson	Signers trusted an upstream system to describe what they were signing	**Same, and automation removed the human pause**

DEVOPS DRILL-DOWN

03 How a laptop becomes a withdrawal

Confirmed: the laptop, the service container and the unauthorized withdrawal submissions[1]. Not yet public: how the laptop was compromised, what credentials it held, how access reached the container, and the "additional points of breach"[4,6]. Commentators suggest a fake job test or similar lure delivered malware[6] UNCONFIRMED. The map below is our general model of the path and where controls should sit OUR ANALYSIS.



DevOps attack path with a control gate at each hop. Any one gate holding would have broken the chain; the signer gate is the last and most important.

Developer workstations — ENDPOINT

North Korea-linked groups target engineers with social engineering; at Safe{Wallet} (Bybit) the lure was a malicious Python application[11]. Production-capable work only from hardened, managed VDI; no prod credentials on general-purpose laptops.

Secrets and identity — IAM

Phishing-resistant MFA (FIDO2), short-lived and device-bound tokens, no long-lived cloud keys or kubeconfigs on disk. Alert on new MFA device registration (attempted in Bybit)[11].

CI/CD and supply chain — PIPELINE

Two-person review on merges and deploys to signing-adjacent services; pinned and verified dependencies; signed artifacts and provenance (SLSA-style); reproducible builds for signing front-ends.

Infrastructure-as-code — IAC

All signing-path infrastructure changes via reviewed Terraform/Helm; drift detection; no console changes; storage buckets serving signing UIs immutable and integrity-checked.

Production access — RUNTIME

No interactive shell into signing-adjacent containers; just-in-time, time-boxed, approved break-glass; workload identity (mTLS) so only the real withdrawal service can call the signer.

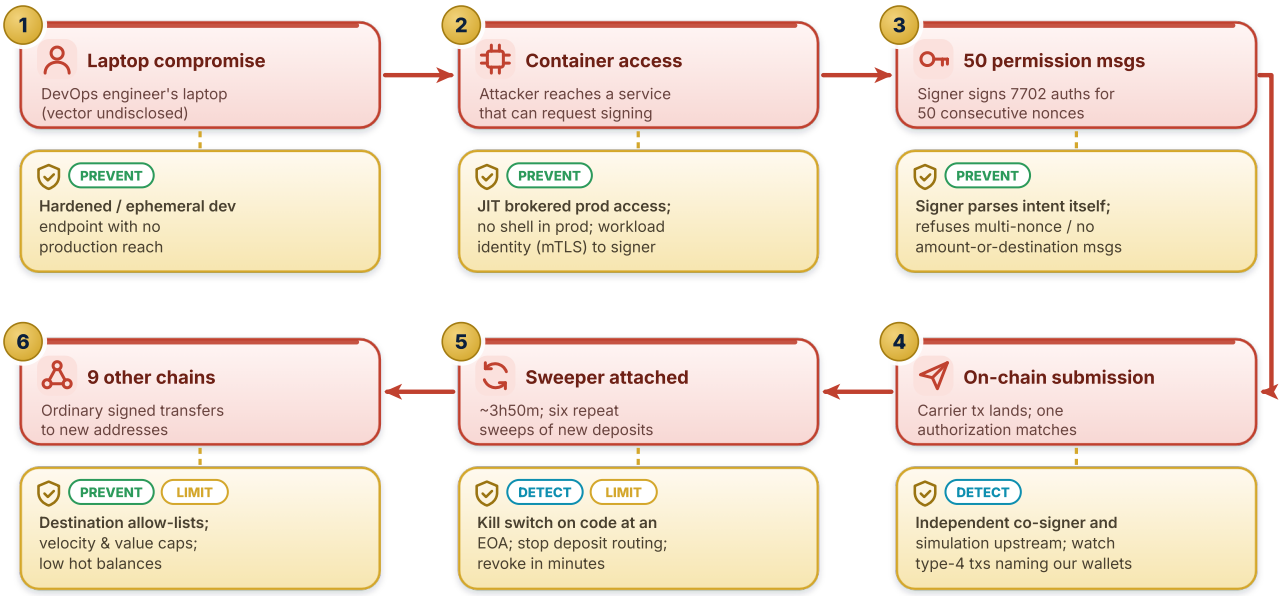
Monitoring — DETECT

Alert on: unusual signing request types or volume, batches over nonce ranges, new destination addresses, code appearing at an EOA (7702), and new stablecoin approvals. Target detect-and-revoke in minutes, not hours.

WHAT COULD HAVE PREVENTED OR CONTAINED THIS

04 Mitigations mapped to each attack step

OUR ANALYSIS **This section is our analysis, not Binance's findings.** Binance has not published a root cause; we map each publicly reported step to controls that could have been in place, and say whether each would **prevent** the step, **detect** it, or **limit** the loss. Several layers were each sufficient on their own; in this kind of chain, one holding is enough.



Attack path (red) with a mitigation at each step (gold). Steps as reported by Binance (1-2) and reconstructed on-chain by TRM and 808bits (3-6) [1,2,3]. Mitigations are our analysis.

Mitigation	How it applies here	Effect
1 · Laptop compromise · DevOps engineer's laptop compromised; vector undisclosed		
Hardened or ephemeral dev endpoint	Production work only from managed VDI or ephemeral, rebuilt-daily workstations; general laptops hold no prod credentials, so a compromised one is not a route in	PREVENT
Phishing-resistant identity	FIDO2 MFA, device-bound, short-lived tokens; stolen session material expires or fails off-device	PREVENT
EDR and behaviour alerts	New persistence, unsigned tooling or unusual credential access on an engineer device raises an alert before the attacker moves on	DETECT
2 · Access to the service container · attacker reaches a production service that can submit withdrawals		
Just-in-time, brokered access	No standing prod access; time-boxed, approved, recorded sessions through a broker; no direct exec or shell into signing-adjacent containers	PREVENT
Workload identity to the signer	Signer accepts calls only from the genuine service's attested identity (mTLS / SPIFFE) and only its normal request types, not from whatever runs inside the container	PREVENT
Prod-access monitoring	Alert on any exec, kubectl or new process in withdrawal or signing services	DETECT
3 · Signing pipeline produces 50 permission messages · EIP-7702 authorizations for 50 consecutive nonces, no amount or destination		
Signer parses intent itself	Signer builds the transaction from a business intent record it reads and parses, rather than signing a payload or digest handed in by an upstream system	PREVENT
Refuse risky message types	Reject EIP-7702 authorizations unless pre-registered; reject any batch spanning multiple transaction counts; reject anything with no amount or destination	PREVENT
Independent co-signer / out-of-band check	A second service run by a different team re-derives each request from the client instruction or settlement record and co-signs only on a match; no match existed here	PREVENT
Simulate before signing	Simulate the post-state: code appearing at the wallet, new controller, approvals. A delegation to an unverified sweeper is flagged	PREVENT DETECT
4 · On-chain submission · attacker-funded carrier transaction lands; one authorization matches		

Mitigation	How it applies here	Effect
Mempool and chain watch	Alert on any type-4 transaction naming our wallets as authority, or any authorization we did not request. Once a valid signature exists, anyone can broadcast it, so controls must sit upstream at step 3	DETECT
5 · Sweeper attached ~3h50m with repeated sweeps[2,3]		
Automatic kill switch	Code appearing at an EOA, or a full-balance outflow, auto-pauses withdrawals and stops routing deposits to that wallet; 326 deposits kept arriving after the drain[3]	DETECT LIMIT
Rehearsed fast revocation	Pre-approved runbook to sign an authorization to the zero address within minutes; Binance's took ~3h50m[3]	LIMIT
Pre-arranged freeze contacts	Standing escalation with stablecoin issuers and security councils; Tether froze 37 min after the main sweep, Circle about 40 min after[2]	LIMIT
6 · Ordinary signed transfers on the other 9 chains · XRP, BTC, Tron, Solana and others to brand-new addresses		
Destination allow-lists	Hot-wallet sweeps and rebalances go only to known addresses; transfers to hour-old addresses blocked	PREVENT
Per-wallet velocity and value caps	Hard limits per wallet, per asset, per hour, enforced in the signer; one 18,270 BTC transfer[2] would breach any sensible cap	LIMIT
Low hot balances, refill from warm/cold	Keep hot wallets to a working float and refill from warm or cold storage on a schedule with separate approval	LIMIT
Segregated signers by chain and tier	One compromised path should not sign for ten chains[2]	LIMIT
Cross-chain anomaly monitoring	Simultaneous large outflows across chains trigger a global withdrawal halt within minutes	DETECT LIMIT

TAKEAWAYS (OUR ANALYSIS)

- **Step 3 is the decisive layer.** A signer that builds what it signs from intent it has parsed, refuses unparsed, multi-nonce or no-amount/no-destination messages, and needs an independent co-signature, would likely have stopped both the Ethereum delegation and the plain transfers, whatever happened at steps 1 and 2.
- **After step 4, signer controls no longer apply.** A delegated wallet runs the attacker's contract directly, so signer-side caps do not see the sweeps. Only the wallet's balance, a kill switch and fast revocation limit the loss from there.
- **Prevention and containment are both needed.** PREVENT controls at steps 1-3 stop the attack; DETECT and LIMIT controls at steps 4-6 turn a multi-billion loss into a bounded one if prevention fails.

RECOMMENDATIONS

05 Controls for an institutional custody and settlement stack

These are general controls drawn from this incident and Bybit; they are not a statement about the current state of any RBC system. Priority: P1 test now · P2 next quarter.

Control	What it does	Would it have helped here?	Pri.
Typed-payload signing only	Signer (MPC or HSM) refuses raw digests; every request is a fully parsed, typed transaction; unknown types (e.g. 0x05 / EIP-7702) rejected by default	Yes: the 50 authorizations would have failed policy[3]	P1
Policy engine with allow-lists	e.g. Fireblocks Transaction Authorization Policy or equivalent: whitelisted destinations, per-asset and per-wallet limits, velocity caps, time windows	Yes: transfers to hour-old addresses on 9 chains[3]	P1
Independent verification	A second service, built and run by a different team, re-derives each transaction from the original business intent (client instruction, settlement record) and co-signs	Yes: no matching business intent existed	P1
Pre-sign simulation	Simulate post-state, not just the transfer: code at addresses, owner/implementation changes, approvals, delegations	Partly: flags delegation; not the plain transfers	P1
Pre-signed blob governance	Inventory, encrypt and expire recovery/sweep transactions; bind to short nonce or time windows; dual control to release	Indirect: limits standing bearer risk	P2
Maker-checker for automation	Bulk or unusual requests (batches, nonce ranges, new types) need human approval out-of-band, even in hot-wallet flows	Yes: a 50-item nonce-range batch is an indicator of compromise[2]	P1
Wallet tiering and limits	Keep hot balances to a bounded working float; segregate signers by chain and tier so one path cannot sign for ten chains	Yes: caps the loss; TRM flags the 10-chain reach[2]	P2
Delegation and code monitoring	Alert when code appears at an EOA; pre-approved, tested revocation transaction; stop deposits routing to a compromised wallet	Yes: delegation ran ~3h50m with six re-sweeps[2,3]	P1
Front-end integrity	Reproducible builds, subresource integrity, signed releases for any signing UI; hardware-wallet or offline display of decoded payload	Bybit-type risk[11]	P2
DevOps hardening	Managed VDI for prod work, FIDO2, JIT access, no shells in prod, signed CI artifacts, IaC-only changes	Yes: breaks the laptop → container hop	P2
Counterparty screening	Screen deposits, OTC and solver fills against labeled attacker addresses (TRM, Chainalysis)	Market makers bought ~$325M USDT from the attacker[2]	P1

Proposed next steps for Digital Asset Technology

- **This week:** confirm with each custody and signing provider whether their policy engine can reject EIP-7702 authorizations and raw-digest requests, and how we would know.
- **Tabletop:** run this scenario (engineer laptop → service that can request signatures) against our hot and warm signing paths, with Global Risk Management and Cyber.
- **Counterparty:** screen for the labeled attacker addresses; track Binance's withdrawal reopening and post-mortem.
- **Follow-up:** refresh this note when Binance publishes its technical post-mortem.

EVIDENCE

Confirmed vs unconfirmed, and sources

Confirmed (Binance statement or on-chain)	Analyst findings / unconfirmed
• Incident on 29 Oct 2026; ~$6.3B impact; ~$3B frozen (Binance) • Initial finding: compromised DevOps laptop → service container → unauthorized withdrawals • No evidence of private-key leak • Withdrawals suspended; deposits operating; affected address authorization revoked • Losses covered by SAFU and company funds; >$6.3B reserved • On-chain: 50-entry EIP-7702 authorization list in block 26300753; sweep of 167,464 ETH; revocation at 00:10:35 UTC	• Attribution to TraderTraitor / Lazarus (TRM, Chainalysis: high confidence; not officially confirmed) • Hot-wallet signing infrastructure compromise as the mechanism (TRM, Blockaid) • Signing ~3 min before broadcast (808bits inference from nonce data) • How the laptop was compromised (fake test/malware is commentary only) • The "additional points of breach" (undisclosed) • Withdrawals reopening in ~45 h (target, not done) • Exact totals: $6.3B / $6.36B / $6.4B depending on source and pricing time

Sources

1. Binance, "Security Incident Update (2026-10-30)": binance.com/en/support/announcement/detail/c5a8729a97ac486d963784d96c5642d7
2. TRM Labs, "North Korea Steals USD 6.36 Billion From Binance..." (30 Oct 2026): trmlabs.com/resources/blog/north-korea-steals-usd-6-36-billion-from-binance-in-the-largest-hack-in-history
3. 808bits, "Binance hot wallet signed 50 authorizations 3 minutes before the drain": 808bits.com/articles/binance-hot-wallet-eip-7702-delegations/
4. BleepingComputer, "Binance links $6.3 billion crypto theft to compromised DevOps laptop": bleepingcomputer.com/news/security/binance-links-63-billion-crypto-theft-to-compromised-devops-laptop/
5. CNBC, "Binance's $6.3 billion hack: What we know and what comes next": cnbc.com/2026/10/30/billions-in-crypto-frozen-in-binance-hack-heres-what-happens-next-.html
6. BBC News live and explainer: bbc.com/news/live/cqrmynd3042gt · bbc.com/news/articles/cm5yn8eqg3npo
7. Cointelegraph (Blockaid), "Binance Links $6.3B Hack to Engineer's Compromised Laptop": cointelegraph.com/news/binance-hack-may-involve-private-key-misuse-not-theft-blockaid-ceo
8. Cointelegraph, "Binance $6.3B Hack Raises Questions Over Ethereum EIP-7702": cointelegraph.com/news/binance-hack-security-ethereum-eip-7702-role
9. CoinDesk, "Here's how an Ethereum upgrade helped drain part of Binance's $6 billion loss": coindesk.com/tech/2026/10/30/...
10. MarketWatch, "Here's when Binance plans to reopen...": marketwatch.com/story/heres-when-binance-plans-to-reopen-...
11. Sygnia, Bybit investigation: sygnia.co/blog/sygnia-investigation-bybit-hack/ · sygnia.co/press-release/bybit-investigation-largest-crypto-heist-lazarus-group/

Prepared by JP Creedon, Head of Digital Asset Technology, RBC Capital Markets, from public reporting as of October 30, 2026, ~10:30 AM ET. The incident is still developing and Binance has not published its technical post-mortem; figures differ by source and pricing time and are quoted with their source. Control recommendations are general and not an assessment of any RBC system. Not legal, accounting or investment advice.